



中华人民共和国通信行业标准

XX/T XXXXX—XXXX

工业互联网数据安全保护要求

Specification for data security protection of industrial internet

点击此处添加与国际标准一致性程度的标识

(报批稿)

2019-12-26

XXXX – XX – XX 发布

XXXX – XX – XX 实施

中华人民共和国工业和信息化部
布

发

目 次

前言..... III

1 范围..... 1

2 规范性引用文件..... 1

3 术语、定义和缩略语..... 1

 3.1 术语和定义..... 1

 3.2 缩略语..... 1

4 数据安全保护范围..... 1

5 工业互联网数据类型..... 1

 5.1 概述..... 2

 5.2 工业互联网设备数据..... 2

 5.3 应用系统数据..... 2

 5.4 知识库数据..... 2

 5.5 企业数据..... 3

 5.6 用户个人数据..... 3

6 工业互联网数据重要性分级与安全保护等级划分..... 3

 6.1 概述..... 3

 6.2 数据重要性等级..... 3

 6.3 数据安全保护等级划分..... 4

7 低重要性数据安全保护要求..... 4

 7.1 数据产生阶段..... 4

 7.2 数据传输阶段..... 4

 7.3 数据存储阶段..... 4

 7.4 数据使用阶段..... 5

 7.5 数据迁移阶段..... 5

 7.6 数据销毁阶段..... 5

8 中重要性数据安全保护要求..... 5

 8.1 数据产生阶段..... 5

 8.2 数据传输阶段..... 5

 8.3 数据存储阶段..... 5

 8.4 数据使用阶段..... 5

 8.5 数据迁移阶段..... 5

 8.6 数据销毁阶段..... 6

9 高重要性数据安全保护要求..... 6

 9.1 数据产生阶段..... 6

9.2 数据传输阶段..... 6

9.3 数据存储阶段..... 6

9.4 数据使用阶段..... 6

9.5 数据迁移阶段..... 6

9.6 数据销毁阶段..... 6

附录 A （资料性附录） 工业互联网数据分类与重要性等级划分示例..... 7

前 言

本标准按照GB/T 1.1-2009给出的规则起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本标准由中国通信标准化协会提出并归口。

本标准起草单位：中国信息通信研究院、长扬科技(北京)有限公司、北京微智信业科技有限公司、深圳华制智能制造技术有限公司、上海观安信息技术股份有限公司、中国电信集团有限公司、中通服咨询设计研究院有限公司、华为技术有限公司、奇安信科技集团股份有限公司、北京奇虎科技有限公司、四川天邑康和通信股份有限公司、通鼎互联信息股份有限公司、新华三技术有限公司、北京启明星辰信息安全技术有限公司、中国科学院信息工程研究所、北京天融信网络安全技术有限公司、工业互联网创新中心（上海）有限公司、浙江鹏信信息科技股份有限公司。

本标准主要起草人：李艺、田慧蓉、柯皓仁、孙娅苹、于广琛、汪义舟、张亚京、陈乔、崔婷婷、唐军、谢江、何国锋、任永攀、王小鹏、高丽芬、杨波、王伟、郭颖、张屹、罗成、马娟、张瑜、李珊、程妍、侯文婷、程博、何芯锐、杨建军、梁贤斌、荣军、万晓兰、雷慧桃、刘健帅、赵军凯、李红、闫兆腾、王龔、王朝栋、栾少群、艾舒欣。

工业互联网数据安全保护要求

1 范围

本标准规定了工业互联网数据安全保护的范围及数据类型、工业互联网数据重要性分级与安全保护等级划分方法，规定了低/中/高重要性数据在数据产生、传输、存储、使用、迁移及销毁阶段的具体安全保护要求。

本标准适用于工业互联网相关服务组织或企业开展数据安全保护工作。

2 规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件，仅注日期的版本适用于本文件。凡是不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25069	信息安全技术 术语
GB/T 35273-2017	信息安全技术 个人信息安全规范
GB/Z 28828-2012	信息安全技术 公共及商用服务信息系统个人信息保护指南
YD/T 2692-2014	电信和互联网用户个人电子信息保护通用技术要求和管理要求
YD/T XXXX-XXXX	工业互联网安全防护总体要求

3 术语、定义和缩略语

3.1 术语和定义

GB/T 25069、GB/T 35273-2017、GB/Z 28828-2012、YD/T 2692-2014以及YD/T XXXX-XXXX的术语和定义适用于本文件。

3.2 缩略语

下列缩略语适用于本文件。

DCS	分布式控制系统	Distributed Control System
ERP	企业资源计划	Enterprise Resource Planning
IP	网络协议	Internet Protocol
MES	生产过程执行系统	Manufacturing Execution System
SCADA	数据采集与监视控制系统	Supervisory Control And Data Acquisition

4 数据安全保护范围

本标准重点对工业互联网数据全生命周期（数据产生、数据传输、数据存储、数据使用、数据迁移、数据销毁）内产生的相关数据进行安全保护。

5 工业互联网数据类型

5.1 概述

工业互联网数据主要包括工业互联网设备数据、应用系统数据、知识库数据、企业数据、用户个人数据五大类。

5.2 工业互联网设备数据

工业互联网设备数据是指工业互联网业务中的工业现场设备、智能设备、智能装备等工业互联网设备在运行过程中所采集或产生的各类数据，以及与设备配置和管理相关的各类数据，细分为工业传感数据、设备运行状态数据、设备配置数据、设备日志数据四类：

- a) 工业传感数据
工业现场设备所采集的各类参数数据，包括但不限于通过传感器采集的温湿度、电流、电压、功率、高度、速度、位置等。
- b) 设备运行状态数据
与工业现场设备的实时运行状态相关的各类参数数据，包括但不限于设备运行监测数据、设备故障数据等。
- c) 设备配置数据
工业现场设备正常运行所需的配置数据，包括但不限于设备使用的 IP 地址、连接设备所使用的协议、需要采集的数据所处的内存地址或寄存器等。
- d) 设备日志数据
工业现场设备运行过程中所生成的日志数据，包括但不限于设备登录日志、运维操作日志、故障告警日志等。

5.3 应用系统数据

应用系统数据是指工业互联网业务中各类应用系统在运行过程中所产生的各类数据，以及与应用系统配置和管理相关的各类数据，可细分为生产控制数据、生产管理数据、系统配置数据、系统日志数据四类：

- a) 生产控制数据
工业互联网业务中与生产控制过程相关的应用系统所产生的各类数据，包括但不限于 SCADA、DCS 等系统的计算或分析结果、控制指令、告警数据等。
- b) 生产管理数据
工业互联网业务中与生产管理过程相关的应用系统所产生与存储的各类数据，包括但不限于 MES、ERP、工业互联网平台、工业 APP、标识解析系统等所产生与存储的生产计划数据、生产管理数据、设备台账数据、生产工艺数据、产量与原材料用量数据、产品生命周期管理数据、资产标识数据等。
- c) 系统配置数据
应用系统正常运行所需的配置数据，包括但不限于系统使用的 IP 地址、端口号、系统账号信息等。
- d) 系统日志数据
应用系统运行过程中所生成的日志数据，包括但不限于系统登录日志、运维操作日志、故障告警日志等。

5.4 知识库数据

知识库数据是指为指导或保证工业互联网业务正常或最优运行所需要的各类数据，可细分为标准文件数据、计算模型数据、环境数据三类：

- a) 标准文件数据
包括但不限于国家和行业标准、电子期刊、专家知识库、数据案例和相关政策信息等。
- b) 计算模型数据
包括但不限于模型计算指标、权重、计算过程等。
- c) 环境数据
包括但不限于地理信息数据、气象数据等。

5.5 企业数据

企业数据指为满足工业互联网业务运营需要及支撑企业业务运行的各类企业相关数据，可细分为企业基础信息数据、企业运营数据两类：

- a) 企业基础信息数据
包括但不限于企业名称，企业商标，企业纳税人识别号，企业规模，企业收入，所属行业，所在地区等相关数据以及营业执照等相关文件。
- b) 企业运营数据
包括但不限于企业在工业互联网平台上维护的其自身组织架构及其用户信息，企业用户权限信息，以及在工业互联网平台上基于业务形成的不同企业间关系（如供应商，客户，合作伙伴，竞对关系等）等相关数据。

5.6 用户个人数据

用户个人数据是指工业互联网业务运营过程中所采集、使用和/或产生的与用户相关的数据。按照GB/T 35273-2017《信息安全技术 个人信息安全规范》、GB/Z 28828-2012《信息安全技术 公共及商用服务信息系统个人信息保护指南》和YD/T2692-2014《电信和互联网用户个人电子信息保护通用技术要求和保护要求》等标准的规定，用户个人数据主要包括身份信息、鉴权信息、日志信息和内容信息等。

6 工业互联网数据重要性分级与安全保护等级划分

6.1 概述

本标准中对于工业互联网数据重要性分级与安全保护等级的划分针对工业互联网设备数据、应用系统数据、知识库数据、企业数据四类数据进行。针对用户个人数据，应遵循GB/T 35273-2017《信息安全技术 个人信息安全规范》、GB/Z 28828-2012《信息安全技术 公共及商用服务信息系统个人信息保护指南》和YD/T2692-2014《电信和互联网用户个人电子信息保护通用技术要求和保护要求》等标准的要求实施安全保护，在此不对用户个人数据的重要性分级与安全保护等级进行划分。

6.2 数据重要性等级

依据工业互联网数据的重要性以及在发生安全事件时可能造成的影响范围与严重程度不同，将工业互联网相关数据划分为不同的重要性等级，并按照等级的不同实施相应的安全保护措施。

本标准将工业互联网数据划分为低重要性数据、中重要性数据和高重要性数据：

a) 低重要性数据

是指在工业互联网业务运行过程中，相关数据出现泄露或被破坏时，会对与工业互联网业务相关的生产商、服务提供商、用户等造成较小影响，但不会对财产和人身安全构成危害，影响范围与程度有限。

b) 中重要性数据

是指数据一旦泄露或被破坏，会对与工业互联网业务相关的生产商、服务提供商造成较大影响，在一定范围内影响经济效益或造成财产损失，或会对用户的人身和财产安全造成较小影响的数据。

c) 高重要性数据

是指在工业互联网的数据活动中，与生产商、服务提供商等企业利益密切相关，或直接关系到用户的个人隐私的数据，这些数据一旦未经授权泄露、丢失、滥用、篡改或销毁，会对与工业互联网业务相关的生产商、服务提供商造成严重影响，在较大范围内严重影响经济效益或造成重大财产损失，或会对用户的人身和财产安全造成严重影响。

工业互联网数据分类与重要性等级划分示例参见附录A。

6.3 数据安全保护等级划分

根据YD/T XXXX-XXXX《工业互联网安全防护总体要求》中对于工业互联网安全防护的等级划分，本标准规定工业互联网的低重要性数据在基本级防护要求的基础上实施保护，中重要性数据和高重要性数据在增强级防护要求的基础上实施保护。

7 低重要性数据安全保护要求

7.1 数据产生阶段

数据产生阶段安全保护要求包括但不限于：

- a) 数据产生时，应标记数据的敏感度等级；
- b) 数据采集方应向数据提供方告知数据的去向及用途。

7.2 数据传输阶段

数据传输阶段安全保护要求包括但不限于：

- a) 应采用技术措施保证鉴别信息（指用于鉴定用户身份是否合法的信息，如用户登录各种业务系统的账号和密码、服务密码等）传输的保密性；
- b) 应支持用户实现对关键业务数据和管理数据传输的保密性；
- c) 应能够检测到数据在传输过程中完整性受到破坏。

7.3 数据存储阶段

数据存储阶段安全保护要求包括但不限于：

- a) 应在保证密码算法安全性的前提下为用户提供对密码算法、强度和方式等参数进行配置的功能
- b) 应提供有效的磁盘保护方法或数据碎片化存储等措施，保证即使磁盘被窃取，非法用户也无法从磁盘中获取有效的用户数据；
- c) 应能够检测到数据在存储过程中完整性受到破坏，防止数据被篡改、删除和插入等操作。在数据完整性遭到破坏时，应提供授权用户可察觉的告警信息；
- d) 应提供数据本地备份与恢复功能，全量数据备份至少每周一次，增量备份至少每天一次，或提供多副本备份机制；
- e) 备份数据应与原数据具有相同的访问控制权限和安全存储要求。

7.4 数据使用阶段

数据使用阶段安全保护要求包括但不限于：

- a) 应对数据的使用进行授权和验证;
- b) 应确保数据仅在工业互联网业务功能范围内使用。

7.5 数据迁移阶段

数据迁移阶段安全保护要求包括但不限于:

- a) 应进行数据迁移前的网络安全能力评估, 保证数据迁移的安全实施;
- b) 应保证数据在不同数据设备之间迁移不影响业务应用的连续性;
- c) 数据迁移中应做好数据备份以及恢复相关工作。

7.6 数据销毁阶段

数据销毁阶段安全保护要求包括但不限于:

- a) 应建立数据销毁审批机制, 设置销毁相关监督角色, 监督操作过程;
- b) 应能够提供手段协助清除因业务终止、自然灾害、合同终止等而遗留的数据;
- c) 数据销毁日志的留存时间不少于 6 个月。

8 中重要性数据安全保护要求

8.1 数据产生阶段

同7.1低重要性数据安全保护要求。

8.2 数据传输阶段

除包括7.2低重要性数据的安全保护要求之外, 还应包括但不限于:

应能够检测到数据在传输过程中完整性受到破坏, 并在检测到完整性错误时采取必要的恢复措施。

8.3 数据存储阶段

除包括7.3低重要性数据的安全保护要求之外, 还应包括但不限于:

- a) 应能够检测到数据在存储过程中完整性受到破坏, 并在检测到完整性错误时采取必要的恢复措施;
- b) 应支持用户选择第三方加密及密钥管理机制对重要业务系统数据进行加密;
- c) 应提供有效的虚拟机镜像文件加载保护机制, 保证即使虚拟机镜像被窃取, 非法用户也无法直接在其计算资源上进行挂卷运行;
- d) 应建设生产备份中心和同城灾备中心, 即双活中心。双活中心应具备基本等同的业务处理能力并通过高速链路实时同步数据, 日常情况下可同时分担业务及管理系统的运行, 并可切换运行, 灾难情况下应支持灾备应急切换, 保持业务连续运行。

8.4 数据使用阶段

除包括7.4低重要性数据的安全保护要求之外, 还应包括但不限于:

应对重要业务系统运行数据的使用进行审计, 并形成审计日志, 审计日志留存时间不少于6个月。

8.5 数据迁移阶段

除包括7.5低重要性数据的安全保护要求之外, 还应包括但不限于:

数据迁移准备应制定迁移方案，并进行迁移方案可行性评估与风险评估，确定制定数据迁移风险控制措施。

8.6 数据销毁阶段

除包括7.6低重要性数据的安全保护要求之外，还应包括但不限于：

- a) 应确保文件、目录和数据库记录等资源所在的存储空间被释放或重新分配给其他用户前得到完全清除；
- b) 应通过提供必要的的数据销毁工具等手段，确保以不可逆的方式销毁数据。

9 高重要性数据安全保护要求

9.1 数据产生阶段

同8.1中重要性数据安全保护要求。

9.2 数据传输阶段

同8.2中重要性数据安全保护要求。

9.3 数据存储阶段

除包括8.3中重要性数据的安全保护要求之外，还应包括但不限于：

- a) 应建立异地灾难备份中心，提供异地实时备份功能，配备灾难恢复所需的通信线路、网络设备和数据处理设备等，利用通信网络将数据实时备份至灾难备份中心；
- b) 异地备份存储设备、存储介质位置应在中华人民共和国境内。

9.4 数据使用阶段

除包括8.4中重要性数据的安全保护要求之外，还应包括但不限于：

- a) 应对数据的使用进行审计，并形成审计日志，日志留存时间不少于6个月；
- b) 应支持数据使用过程中的动态脱敏。

9.5 数据迁移阶段

同8.5中重要性数据安全保护要求。

9.6 数据销毁阶段

同8.6中重要性数据安全保护要求。

附 录 A
(资料性附录)

工业互联网数据分类与重要性等级划分示例

一个工业互联网数据分类与重要性等级划分的示例如表A.1所示，其中打“√”的位置表示该类数据对应的重要性等级。

表A.1 工业互联网数据分类与重要性等级划分示例表

工业互联网数据类型		重要性等级		
		低重要性数据	中重要性数据	高重要性数据
工业现场设备数据	工业传感数据	√		
	运行状态数据		√	
	设备配置数据		√	
	设备日志数据	√		
应用系统数据	生产控制数据			√
	生产管理数据			√
	系统配置数据	√		
	系统日志数据	√		
知识库数据	标准文件数据	√		
	计算模型数据		√	
	环境数据	√		
企业数据	企业基础信息数据	√		
	企业运营数据			√
用户个人数据	身份信息	遵循 GB/T 35273-2017 《信息安全技术 个人信息安全规范》、GB/Z 28828-2012 《信息安全技术 公共及商用服务信息系统个人信息保护指南》和 YD/T 2692-2014 《电信和互联网用户个人电子信息保护通用技术要求和管理要求》等标准的要求实施安全保护，在此不进行划分		
	鉴权信息			
	日志信息			
	内容信息			